

CVE — Study Guide

CVE (Common Vulnerabilities and Exposures) is the universal naming/identifier system for publicly known vulnerabilities — every tool in your recent series (NVD, Nessus, OpenVAS, Nuclei, your own SmartScan project) ultimately organizes its findings around CVE IDs, making this the "primary key" that ties your entire vulnerability management study arc together.

1. What CVE Actually Is

CVE is **not** a vulnerability database itself — it's a standardized **naming convention/dictionary** maintained by MITRE (funded by CISA/DHS) that assigns a unique identifier to each publicly disclosed vulnerability, so that different vendors, researchers, and tools can all refer to the exact same issue unambiguously.

Without CVE: "the Apache bug from last March" (ambiguous, which bug? whose report?)
With CVE: "CVE-2021-41773" (globally unique, unambiguous, everyone means the same thing)

2. CVE ID Format

CVE-YYYY-NNNNN

CVE-2017-0144 ← EternalBlue (year 2017)
CVE-2021-44228 ← Log4Shell (year 2021)
CVE-2019-0708 ← BlueKeep (year 2019)

- **YYYY** — the year the CVE was *assigned* (not necessarily disclosed or discovered — a CVE reserved in 2023 might not be publicly disclosed until 2024)
- **NNNNN** — a sequential number, now variable-length (originally 4 digits, expanded to accommodate the huge growth in annual CVE volume — some IDs now run 5-7+ digits)

3. The CVE Lifecycle

- | | |
|--|---|
| 1. Discovery | → researcher/vendor finds a vulnerability |
| 2. CNA Assignment
(public disclosure) | → a CVE Numbering Authority reserves a CVE ID (often before public disclosure) |
| 3. Disclosure | → details published (coordinated disclosure, or sometimes full/public disclosure) |
| 4. NVD Enrichment | → NIST's National Vulnerability Database adds CVSS score, CWE classification, affected products |
| 5. Ongoing tracking | → status can be RESERVED → PUBLISHED → sometimes REJECTED/DISPUTED |

CVE States worth knowing:

State	Meaning
RESERVED	ID assigned but details not yet public
PUBLISHED	Full details available
REJECTED	Turned out not to be a valid/distinct vulnerability
DISPUTED	The vendor or another party disputes the finding

4. CNAs (CVE Numbering Authorities)

CVE IDs aren't all issued by MITRE directly anymore — **CNAs** are organizations authorized to assign CVE IDs within their own scope:

- | | |
|----------------------------------|---|
| MITRE | → the root CNA, assigns to anyone without a more specific CNA |
| Microsoft, Google, Red Hat, etc. | → vendor CNAs, assign IDs for their own products |
| GitHub | → CNA for open-source projects hosted there |
| CERT/CC | → coordination-focused CNA for multi-vendor issues |

This distributed model is why a CVE can be reserved by a vendor well before public disclosure — the vendor's own CNA assigns the ID internally while they prepare a patch, then disclose once a fix is ready (coordinated/responsible disclosure).

5. CVE vs. NVD — A Critical Distinction

This trips people up constantly:

	CVE (MITRE)	NVD (NIST)
What it is	The naming/ID system, minimal description	The enriched database — adds CVSS scores, CWE mapping, affected product lists (CPE), references
Maintained by	MITRE	NIST
Your SmartScan project	—	This is exactly what your NVD API integration queries

```
# CVE.org - the bare identifier and description
https://www.cve.org/CVERecord?id=CVE-2017-0144
```

```
# NVD - the enriched version with CVSS, CWE, references
https://nvd.nist.gov/vuln/detail/CVE-2017-0144
```

Practical takeaway: when you look up "a CVE," you're almost always actually looking at NVD's enrichment of it, not the bare MITRE record — worth knowing they're two related but distinct systems.

6. Looking Up CVEs — Practical Sources

bash

```
# NVD API (what SmartScan already uses)
curl "https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2017-0144"

# MITRE's own CVE search
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0144

# Vendor advisories (often published alongside the CVE)
https://msrc.microsoft.com/update-guide/vulnerability/CVE-2017-0144
```

7. CVE in Your Existing Toolchain

You've encountered CVE constantly across this whole study series without it always being named explicitly:

```
NSE scripts      → smb-vuln-ms17-010 checks specifically for CVE-2017-0144
Nessus/OpenVAS   → every finding is tagged with a CVE ID
Nuclei templates → organized in folders literally named by CVE year
                  (cves/2021/, cves/2024/)
CVSS             → the scoring system attached to each CVE
SmartScan v2.0   → your entire NVD lookup module IS a CVE lookup pipeline
```

8. A Genuinely Famous CVE, Fully Traced (Study Example)

CVE-2017-0144 (EternalBlue):

```
CNA: Microsoft
Affected: SMBv1 on multiple Windows versions
CVSS v3.1: 8.1 (High) — AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
CWE: CWE-119 (Improper Restriction of Operations within Memory Buffer Bounds)
Disclosed: March 2017 (patch released same month, ahead of the Shadow Brokers leak)
Exploited by: WannaCry (May 2017), NotPetya (June 2017)
CISA KEV: Listed (confirmed active exploitation)
```

This single CVE demonstrates the full chain your entire series has built toward: Nmap/NSE detects it → CVSS scores its severity → CWE classifies its root cause type → CISA KEV confirms real-world exploitation → patch management is the actual fix.

9. CVE Numbering Growth — Worth Knowing the Scale

CVE volume has grown dramatically — tens of thousands of CVEs are now published annually (compare this to a few thousand per year a decade ago), largely driven by the explosion of open-source software, IoT devices, and more CNAs actively assigning IDs. This scale is exactly *why* prioritization frameworks like VPR/EPSS/KEV from your last guide are necessary — no team can meaningfully review every CVE affecting their stack without automated triage.

10. Limitations of the CVE System (Worth Understanding)

- **Not every vulnerability gets a CVE** — many are fixed silently by vendors without public disclosure, or affect software with no active CNA coverage
 - **Assignment delays** — a vulnerability can be known/exploited before its CVE is publicly assigned or enriched by NVD, creating a dangerous gap
 - **NVD enrichment backlog** — NVD has periodically fallen behind on enriching newly published CVEs with CVSS/CWE data (a well-known industry pain point in recent years), meaning a fresh CVE ID might exist with no severity score attached for a while
 - **Quality varies by CNA** — some CNAs provide detailed, well-classified records; others are sparse
-

11. Kill Chain / ATT&CK Mapping

CVE isn't itself a technique — it's the **identifier layer** referenced throughout Reconnaissance (T1595.002 — Vulnerability Scanning) and Exploitation-stage techniques (T1190, T1203) whenever a specific known vulnerability is involved.

Quick Reference Cheat Sheet

Format: **CVE-YYYY-NNNNN**

Assigned by: **CNAs** (**MITRE** + authorized vendors/orgs)

States: **RESERVED** → **PUBLISHED** (or **REJECTED/DISPUTED**)

CVE.org → bare **ID** + description

NVD → enriched with **CVSS**, **CWE**, **CPE**, references

```
curl "https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2017-0144"
```